

Access Control Policy

Table of contents

1. Purpose and scope	2
2. Policy statements	2
2.1 Access authorisation and termination	2
2.2 Shared secrets management	3
2.3 Privileged access management	3
3. Controls and procedures	4
3.1 Standards for access provisioning	4
3.2 Password management	5
3.3 Single sign-on	7
3.4 Multi-factor authentication	7
3.5 Role-based access control	8

Title	Access Control Policy
Doc#	POL-SECU-021
Version	1.4
Date	10-03-2025
Supersedes	POL-SECU-021 v1.3 (15-03-2024); absorbs former POL-SECU-019 (Password Management)
Next Review	10-03-2026
Owner	Chief Information Security Officer (I. Ferreira)
Approved By	Chief Information Officer (A. Vasquez)
ISO/IEC 27001:2022	A.5.15 Access control; A.5.16 Identity management; A.5.18 Access rights; A.8.2 Privileged access rights; A.8.3 Information access restriction

[Reviewer, 2025-03-04: this revision folds the former standalone Password Management policy (POL-SECU-019) into §3.2. Templates and the joiner pack may still cite POL-SECU-019 by its old number — redirect them to this document rather than re-issuing the old one.]

1. Purpose and scope

Access to Tessera systems, networks, devices and applications is granted on a least-privilege basis and protected by strong authentication, authorisation and auditing. This policy gives effect to **APP 11** (security of personal information) of the *Privacy Act 1988* (Cth) and to Annex A controls **A.5.15, A.5.16, A.5.18, A.8.2 and A.8.3** of ISO/IEC 27001:2022. It applies to everyone who is granted access to Tessera resources — workforce members, contractors, consultants, partners and tenants — whether they connect from Tessera premises, remotely, or from Tessera-managed or bring-your-own devices.

Every user is responsible for reporting suspected unauthorised access to Tessera information systems to the Security team without delay.

2. Policy statements

Tessera policy requires that:

- (a) access to all computing resources — servers, end-user devices, network equipment, services and applications — is protected by strong authentication, authorisation and auditing;
- (b) interactive access is tied to an account or login unique to each individual user;
- (c) all credentials, including user passwords, service accounts and access keys, meet the length, complexity, age and rotation requirements in Tessera Security Standard **SEC-STD-003**;
- (d) strong passwords and multi-factor authentication are used wherever the resource supports them;
- (e) **multi-factor authentication is required for access to every production environment and critical system**, with no exception for convenience;
- (f) unused accounts, passwords and access keys are removed within 30 days of last use;
- (g) a distinct access key or service account is used for each application or automated user;
- (h) authenticated sessions time out after a defined period of inactivity.

2.1 Access authorisation and termination

- (a) Access authorisation is implemented through role-based access control (RBAC) or an equivalent mechanism.
- (b) Standard access for a user's job role may be pre-provisioned during onboarding. Any subsequent access request must be approved by the requestor's manager before it is provisioned.

- (c) Access to critical resources — including production environments — requires additional approval from the Security team. (“Critical resources” are defined by data classification; see POL-DATA-001, now issued as the **Data Classification & Lifecycle Policy, POL-DATA-002.**)
- (d) Access is reviewed on a regular basis and revoked when no longer required.
- (e) On termination of employment or engagement, all system access is revoked and user accounts disabled **within 24 hours** of termination, in accordance with the joiner-mover-leaver procedure **ISMS-PR-014**.

(I. Ferreira, note to self: confirm the §2.1(e) wording matches ISMS-PR-014 verbatim before the Stage 1 audit — the HR handbook still quotes a different figure and we do not want two numbers in print.)
- (f) All access is reviewed at least annually and whenever a user’s role changes.

2.2 Shared secrets management

- (a) Use of shared credentials and secrets is minimised and approved only by exception.
- (b) Where business operations genuinely require a shared secret, it is shared securely and held in an encrypted vault that meets Tessera’s data encryption standard (see the Data Protection Policy).
- (c) Use of a shared secret to reach a critical system is always paired with a compensating control that uniquely identifies the individual acting.

2.3 Privileged access management

- (a) Users do not log in directly to systems as a privileged user. A privileged user is anyone with administrative access to critical systems — for example an Active Directory domain administrator, the root user of a Linux host, or the root user of an AWS account.
- (b) Privileged access is obtained only through a proxy or equivalent that enforces strong authentication (MFA) on a unique individual account and records full session audit.
- (c) Direct administrative access to production is kept to an absolute minimum.

[Reviewer, 2025-02-27: this section was rewritten after TSR-INC-2025-031. The 2023 boundary model is no longer in service — confirm the segmentation language still describes the current management/tenant separation before relying on it operationally.]

3. Controls and procedures

3.1 Standards for access provisioning

Workforce clearance

1. The access a user receives is based on the minimum necessary to perform the duties of their role.
2. All access requests are assessed against the least-privilege principle.
3. Tessera operates a minimum-necessary approach to tenant data. Workforce members do not hold standing access to tenant personal information; any access is just-in-time, logged, and revoked when the task completes.

Access authorisation

1. Role-based access categories for each Tessera system and application are pre-approved by the CISO.
2. Tessera uses hardware- and software-defined boundaries to segment data, block unauthorised access, and monitor traffic.

// TODO before next review cycle: link the segmentation runbook (SOP-NET-00x) // once Hamish's team publishes it — the 2023 architecture diagrams no longer // match the live tenant VPC layout.

Person or entity authentication

1. Each workforce member has and uses a unique user ID and password that identifies them as the user of the information system.
2. Each customer and partner has and uses a unique user ID and password, or an OpenID Connect identity, that identifies them as the user of the information system. Customer and partner authentication is enforced through **Auth0**.
3. All customer-support interactions are identity-verified before Tessera support staff act on any request with information-security implications.

Unique user identification

1. Access to Tessera platform systems and applications is controlled by unique login IDs and passwords for each individual user and developer.
2. Passwords meet the strong-password controls in §3.2.
3. Passwords are never displayed and are never transmitted or stored in plain text.
4. Default accounts on all production systems and environments — including root — are disabled or locked.

5. Shared accounts are not permitted within Tessera systems or networks.

Automatic logon and logoff

1. Automated logon configurations that store user passwords or bypass password entry are not permitted on Tessera workstations or production systems.
 - Automatic logon is allowed only for low-risk systems such as a conference-room PC driving a Zoom Room.
 - Such systems sit on a separate network VLAN.
2. Users must secure any information system when leaving it unattended — for example by engaging a password-protected screen saver or logging off.
3. Information systems automatically lock users — for example by engaging a password-protected screen saver — after 2 minutes or less of inactivity.
4. Information systems automatically enter standby or log users off after 30 minutes or less of inactivity.
5. The CISO must pre-approve any exception to the automatic log-off requirements.

3.2 Password management

1. User IDs and passwords control access to Tessera systems and must not be disclosed to anyone for any reason.
2. Users must not allow anyone, for any reason, to access an information system using another user's unique credentials.
3. On all production systems and applications in the Tessera environment, password configurations require:
 - a minimum length of 12 characters;
 - a mix of upper-case, lower-case and numeric or special characters;
 - no reuse of the last 24 passwords, with at least 6 characters changing on each change;
 - account lockout after 5 invalid attempts.

Tessera's baseline position, consistent with NIST SP 800-63B, is that accounts continuously protected by MFA are **not** subject to forced periodic rotation. Forced rotation is retained only for a small number of accounts that cannot be MFA-enrolled.

[Reviewer, 2025-03-06: the prior 60-day blanket rotation is still contractually required for two legacy financial-services tenants until their contract renewals in late 2025 — leave the rotation profile in the IdP until then, do not “tidy” it away.]

4. All system and application passwords are stored and transmitted securely.
 - Where supported, passwords are stored hashed using a salted cryptographic hash (SHA-256 or a stronger NIST-compliant standard).
 - Passwords that must be stored in a non-hashed form are encrypted at rest under the [Data Protection Policy](#).
 - Passwords transmitted over a network are encrypted in flight under the [Data Protection Policy](#).
5. Each information system prompts users to change passwords at an interval set by the system owner and the Security team, based on the criticality and sensitivity of the data it holds.
6. Passwords are inactivated immediately on termination of employment, as part of the 24-hour offboarding run in ISMS-PR-014 (see [HR policy](#)).
7. All default system, application and vendor-provided passwords are changed before deployment to production.
8. On first login, users must change any password that was auto-generated for them.
9. Password-change flows use a confirmation step to catch input errors.
10. All passwords used in configuration scripts are secured and encrypted.
11. If a user believes their user ID has been compromised, they must report it immediately to the [Security team](#).
12. Where a user has forgotten a password, the reset process provided by the IdP applies; the exact flow depends on the system. If help is needed, users contact [IT Support](#) or [Security](#).
13. An approved password manager stores or shares non-critical business application passwords that are not wired into the primary IdP through SSO.
 - The password manager encrypts the local vault with the user’s master password before synchronising to the cloud.
 - The master password meets the requirements above.
 - MFA is enabled on the password-manager account.
 - Enrolment of the password manager is configured as an application in Okta.

[Reviewer, 2025-03-04: “Okta” above is stale — the IdP migration to Auth0 completed in 2024 and this integration now lives there. Correct on the next pass; left in place deliberately so the change is visible in the ticket trail.]
14. An automated screening step prevents use of compromised or common dictionary passwords. This is implemented at the IdP (Auth0).

3.3 Single sign-on

- Tessera uses **Auth0** as its primary identity provider (IdP) to control user access to systems and business applications.
- Single sign-on (SSO) is used in preference to local authentication wherever a target application supports it. Centralising identity at the IdP improves the user experience and simplifies joiner-mover-leaver management.
- SSO is configured over industry-standard SAML between Auth0 and the target application.
- Tessera will not configure SSO to a target application unless it scores a **B** rating or higher on the [Qualys SSL Labs](#) benchmark.
- The Security team administers the IdP and SSO platform, including user and access provisioning, and may delegate administrative rights over a defined subset (for example a single application) to another team.

3.4 Multi-factor authentication

Multi-factor authentication (MFA) is a standard Tessera control for strong access to critical systems and applications, and is enabled wherever a resource supports it. Tessera implements MFA through Auth0.

MFA is required for access to every production environment and critical system.
The rollout is complete; there is no partial-coverage state and no standing exemption.

[Reviewer, 2025-02-18: the earlier “85% of critical systems by Q2 2024” figure is retired — Project MFA-COMplete closed out at 100% in November 2024. Remove any deck or dashboard still quoting the old partial number.]

!!! important

****Approved MFA methods:****

- Push notification via the Authenticator mobile app (default and preferred for end-user access)
- Hardware security key (required for the root user of AWS accounts)
- A unique cryptographic certificate bound to a device
- Time-based one-time password (TOTP) via an authenticator app
- One-time passcode via SMS, only where it is the sole method a target supports
- Secure physical facility, where a system can only be accessed at that location

[Reviewer, 2025-03-06: SMS remains listed as a last-resort factor. NIST SP 800-63B deprecates SMS for authentication; the plan is to retire it once the two remaining integrations move to TOTP — track under the MFA-COMplete closure ticket.]

3.5 Role-based access control

By default, user access is granted according to job function, for example:

- Developer
- Security
- IT
- Administrative
- Marketing / Sales

Roles are defined as **user groups** in the IdP (Auth0), and entitlements are derived from group membership rather than granted to individuals.

Access to sensitive data and production tenant data is highly restricted and is further defined in the Data Classification & Lifecycle Policy (POL-DATA-002, formerly POL-DATA-001).

Document status: v1.4, last reviewed 03-03-2025. Next scheduled review: 10-03-2026. Questions about this policy go to security@tessera.locoensayo.org.